

Can IoT security be tested without the device?

Oliver Wright
BSc (Hons) Ethical Hacking

BACKGROUND AND PROBLEM

IoT devices are everywhere and **dangerously insecure**. Concerningly, over **50% of IoT devices** contain **critical vulnerabilities** that can be actively **exploited [1]**. Testing their firmware requires **physical hardware** which is **expensive, slow, and impossible to perform at scale**. Firmware **emulation** promises a **cheaper, faster** alternative. But how **reliable** is it for real world testing in its **current state**?

METHODOLOGY

Three **sandbox environments** were created, each utilizing a **different emulation** method:

- 1. **FirmAE [2]** (Automated Tool)
- 2. **EMBA [3]** (Automated Tool)
- 3. **QEMU** (Manual Emulation Setup)

A **dataset** was comprised of **5 firmware images**, each from a **different vendor**.

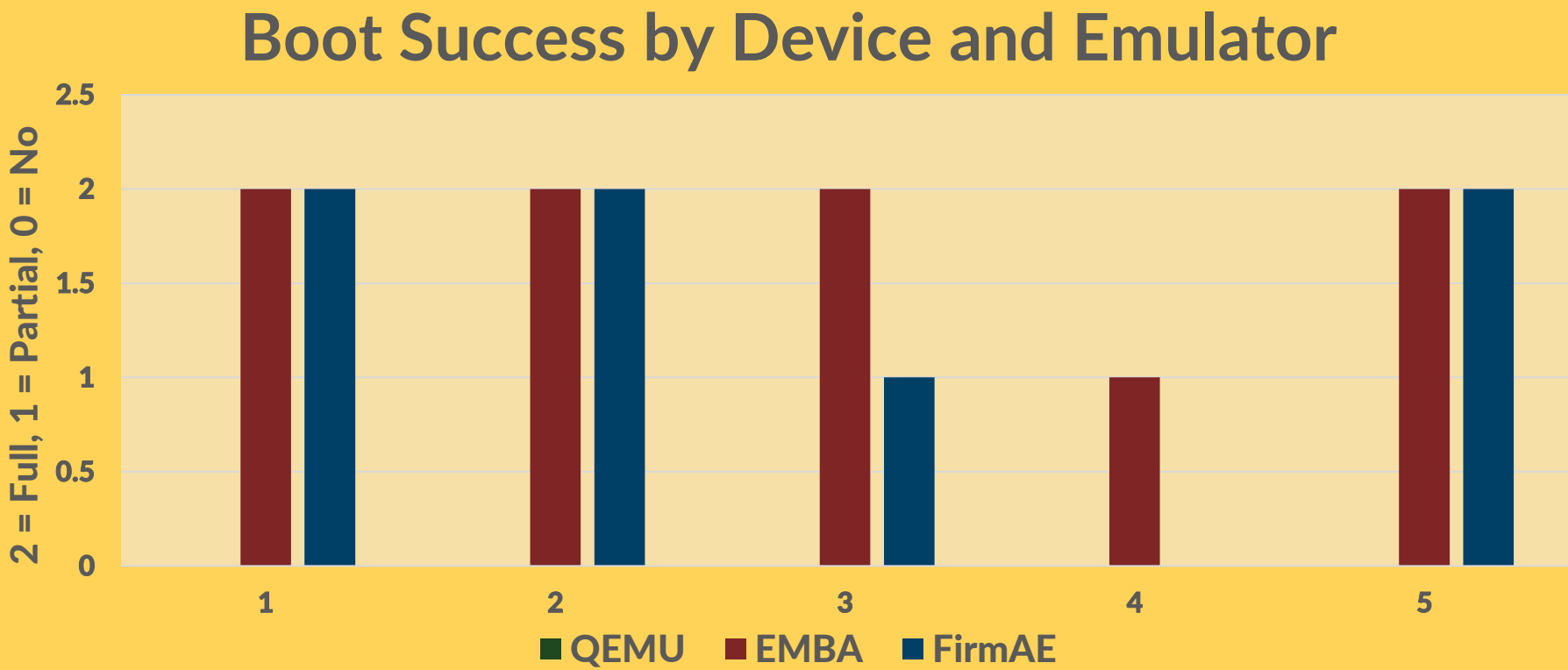
A proper evaluation of the field requires **testing of:** (A) emulation boot success with different devices and emulators (B) vulnerability replication accuracy (C) niche challenges and technical issues exclusively present in emulation.

FirmAE and **EMBA** were selected to test (A) & (B). **Manual QEMU** setup was performed to help grasp (C).

Upon achieving a **successful boot**, **vulnerability testing** was carried out using known **CVEs** for the devices.

RESULTS

Firmware emulation boot success varies with device type, firmware vendor, and emulator used.



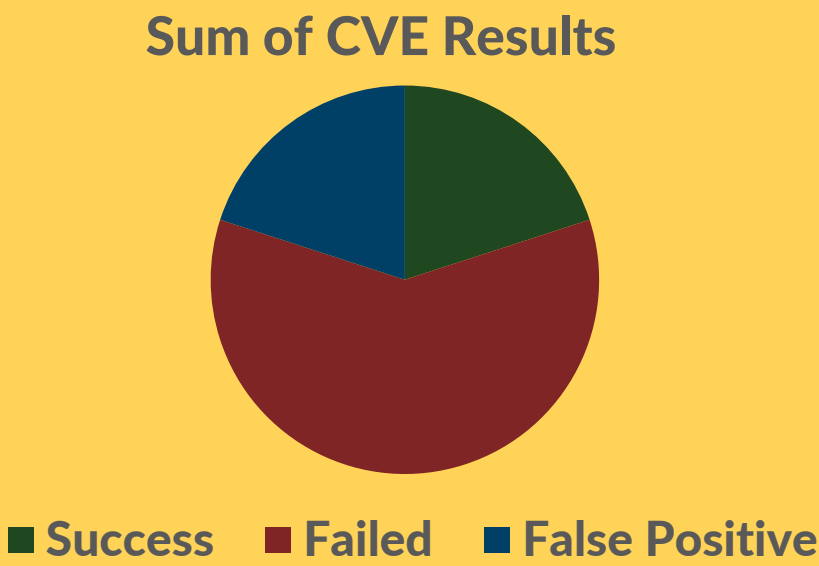
- **EMBA** achieved the highest boot success.
- **FirmAE** was consistent with **Wi-Fi routers**.
- **QEMU** did not yield a successful boot.

Vulnerability replication is inconsistent and often failed for different reasons.

The **DIR-645** successfully replicated **CVE-2023-33625** but failed with **CVE-2014-100005**.

The **R7000** failed to replicate **CVE-2016-6277** & **CVE-2021-31802** due to an **Identification** issue.

EMBA's one verified vulnerability was a **false positive** in the **R7000**.



Failure of both firmware boot and vulnerability replication were caused by unique issues.



The most **common** issue observed during firmware boot was **NVRAM** errors. **FirmAE** and **EMBA** resolve this using a **custom NVRAM** library to emulate the hardware.

Vulnerability replication failed due to a **firmware identification** error, a **functionality** error preventing the exploit from **connecting back**, and a **false positive** caused by **Metasploit** mistaking a **service** for a **different service**.

DISCUSSION

Emulation functionality is not **binary**. A device can **appear fully emulated** but still **partially fail** behind the scenes. The **R7000** demonstrated this as the web interface **functioned** properly and **correct services** were **running**; however, **Metasploit** failed to **fingerprint** it as **Netgear**.

NVRAM is the **central technical barrier**. The lack of **NVRAM** emulation caused **most** of the persisting **boot failures** experienced throughout **manual QEMU**. **FirmAE** and **EMBA** use an **NVRAM** emulation library from their predecessor **Firmadyne** to **bypass** this issue.

Tools had **different strengths** and **limitations**.

1. **FirmAE** is **fast** at setting up emulation and **reliable** with **router** firmware but heavily restricted from working with **other devices**.
2. **EMBA** is **slower** but more **in-depth** and achieved **higher boot rates**. However, **EMBA** produced a **false positive** vulnerability.
3. **Manual QEMU** is extremely **slow** but allows more **configurability** and has the **capability** to emulate firmware which **fails** with **automated emulators**. In most cases, **QEMU** alone is **not enough** to produce a **successful boot** and requires **custom libraries** to be **developed** addressing the specific device being **emulated**.

CONCLUSIONS

Firmware emulation is **inconsistent** and cannot reliably replace **real-world testing** in its **current state**. However, emulation could be used for **initial analysis** and some **vulnerability discovery**, to be checked **manually** during physical device testing. Currently, **FirmAE** is the **most suitable** tool for **router related** firmware **testing**, whereas **EMBA** should be used for testing any **other type** of device firmware due to its **increased boot success rate**.

REFERENCES

Sawant, S. (2025). Security Vulnerabilities in IoT Systems: A Comprehensive Analysis of Threats and Solutions (Medium).
Kim, M. et al. (2020). Proceedings of the 36th Annual Computer Security Applications Conference
EMBA Contributors (2021). EMBA: Embedded Linux Analyzer.